Man vs Internet

Current challenges and future tendencies of establishing trust between humans and machines

Luis Grangeia

BSidesLisbon 2013

Image stolen from manvinternet.com

About me

Luis Grangeia <luis.grangeia at gmail.com>

- IT Security Auditor (pen-tester) since 2001
  - First at SideStep, now at SysValue
- Computer nerd since 1987
- Breaking stuff (and failing to fix it back) since 1979

Agenda

- What’s this about
- The curious case of Mat Honan
- Trust and Authentication
- Future Tendencies
- Strategies for pitfall avoidance

About this talk

- This is **not** about:
  - Open Source Intelligence
  - The NSA
  - SQL Injection or Buffer Overflows
- This **is** about:
  - [Establishing | Maintaining | Exploiting] trust relations between users, devices and services
  - Explore current problems and future tendencies in authentication
  - “Meta” stuff to start a dialogue

The “Mat Honan Hack”

From zero to total online identity compromise

Meet Mat Honan

- Tech savvy blogger/writer for Gizmodo, Wired
- Strong online presence:
  - Twitter
  - About.me
  - Apple Account
  - Google Account
  - Etc.
- Has a cool twitter handle: twitter.com/mat
- **Is about to get hacked**

Mat Honan
Timeline: August 3rd 2012

- 16h33: Someone calls AppleCare pretending to be Mat Honan, provides for some security information and asks for a temporary password.
- 16h50: A password reset confirmation arrives at Mat's me.com mailbox, completing the hijacking of the Mat's iCloud service.
- 16h52: A Gmail password recovery email arrives at Mat's me.com address. Two minutes later another email arrives informing of a password change on the Gmail account.
- 17h00: Mat's iPhone is remotely wiped via iCloud.

Mat Honan
Timeline: August 3rd 2012 (cont.)

- 17h01: Mat's iPad is remotely wiped via iCloud.
- 17h02: Mat's Twitter account is reset. The password his sent to his compromised Gmail Account.
- 17h05: Mat's Macbook is remotely wiped via iCloud (containing the only copies of the birth of his baby daughter).
- 17h05: Mat's entire Google account, containing 8 years worth of personal e-mail messages, is deleted.
- 17h12: Attackers post a message to his Twitter account, taking credit for the hack.

kebcnn

"MY ENTIRE DIGITAL LIFE WAS DESTROYED"
Hack of Wired reporter prompts changes at Apple

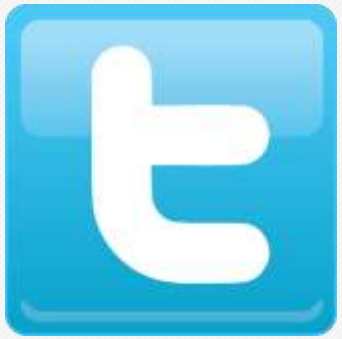
LIVE CNN

WORLD

Egypt pours military might into North Sinai

NAS ▲ 7.75

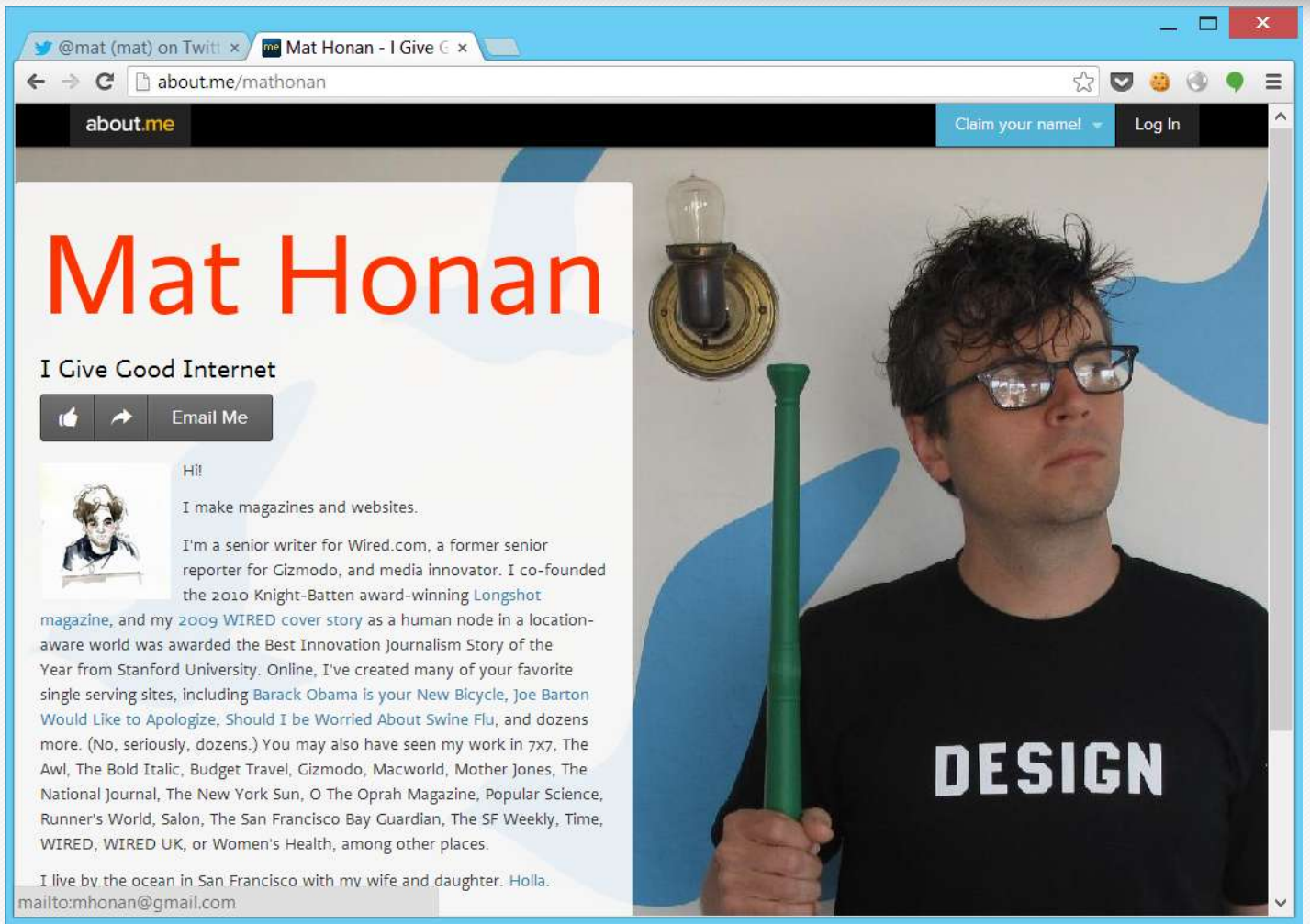
Hacking Mat Honan



twitter.com/mat

Hacking Mat Honan

Hacking Mat Honan

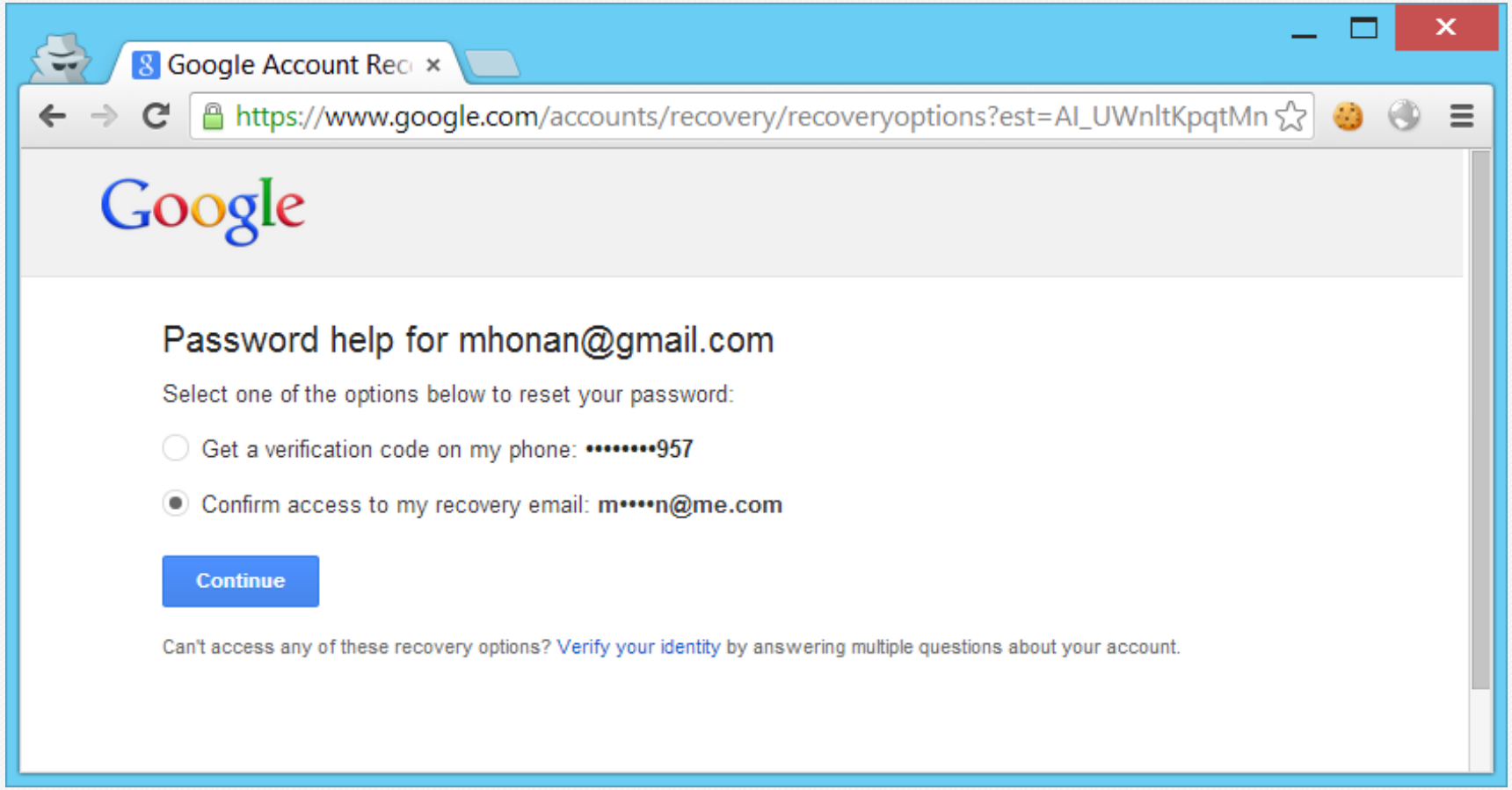


Hacking Mat Honan

twitter.com/mat

mhonan@gmail.com

Hacking Mat Honan



Hacking Mat Honan

twitter.com/mat

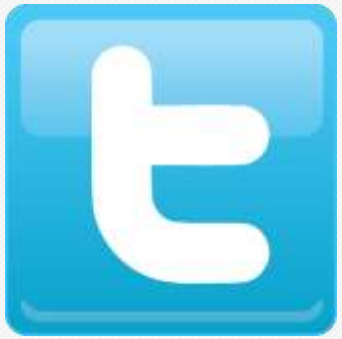
mhonan@gmail.com

mhonan@me.com

Hacking Mat Honan
Time to call Amazon

- Time to call Amazon's phone support
- Call #1:
  - "Hi, my name is Mat Honan, please add a new Credit Card 123 number to my account. My billing address is xyz. Thanks!"
- Call #2:
  - "Hi, I'm Mat Honan. Please add e-mail address evil@me.com to my account. Here is credit card information 123 to verify my identity."
- Step #3:
  - Ask for password reset e-mail to evil@me.com address

Hacking Mat Honan



Account owned!

twitter.com/mat

Account owned!

mhonan@gmail.com

Account owned!

mhonan@me.com

Account owned!

Last 4 digits of Mat's real credit card

What went Wrong?

- Poor password choices?
- Poor phone identity verification procedures?
- Bad trust relationship choices by Mat?
- Lack of 2-factor authentication? Where?

- What could we do better?

Authentication and Trust

Back to basics

Authentication vs Trust

- **Authentication**: To provide **proof of identity** by means of one (or more) of these:
  - Something you know
  - Something you have
  - Something you are
- **Trust**: belief in the reliability, truth, ability, or strength of someone or something.

- **Authentication** is impossible to do without **Trust**!

Something you **know**

- Passwords
- Answers to ‘secret’ security questions
- Date of Birth, registered VISA, home/billing address, email, etc.

Something you **know**: Passwords

- **Password Problems**

- Simple passwords
- Same password used across services
- Services get hacked all the time
  - Over 280 million password hashes leaked (2010-2012)
- Once the hash is out there, its probably getting cracked
  - Eg. Google ‘qeadzcwrsfxv1331’

Something you **know**: Passwords

- **In the Mat Honan Hack:**

- Mat used 1Password
- Long and robust password to decrypt keyfile
- Master password not used anywhere else
- Keyfile was stored in Dropbox and synced across all his devices
- Caveat: **never** send master password through the network or type it on a device you don’t absolutely trust.

Something you **know**: Other

- **Answers to ‘secret’ security questions**
- **Date of Birth, registered VISA, home/billing address, email, etc.**

- Information leaks by services
- Answers can be found on Google
- If it is a secret answer, why am I giving it away?

Something you **know**: Other

Security Questions

Edit or Delete a Payr

https://www.amazon.co.uk/gp/css/account/cards/view.html

amazon.co.uk Luis's Amazon | Today's Deals | Gift Cards | Sell | Help

Shop by Department Search All Go

Amazon.co.uk Warehouse Deals Subscribe & Save Amazon Family Outlet Amazon Prime Mo

Your Account > Edit or Delete a Payment Method

The following payment methods are currently associated with

Changes made to your payment methods will not affect
If you want to edit the method of payment for an order that ha
If you want to add a new credit

Edit or Delete a Payment

Type:	Visa/Delt
Number:	*******
Exp. Date:	04/2011
Cardholder Name:	JOHN DC
Invoice Address:	John Doe Av. Liber Lisboa, L Portugal Phone: +

Google Account Rec

https://www.google.com/accounts/recovery/recoveryoptions?est=AI_UWnltKpqtMn

Google

Password help for mhonan@gmail.com

Select one of the options below to reset your password:

Get a verification code on my phone: ••••••••957

Confirm access to my recovery email: m••••n@me.com

Facebook

https://www.facebook.com/recover/initiate

facebook

Email or Phone Password Log in

Keep me logged in Forgotten your password?

Reset Your Password

How would you like to reset your password?

Email me a link to reset my password
|**********a@gmail.com

Luis Grangeia
Facebook user

Not You?

Something you **know**: Other

- **In the Mat Honan hack:**

- Google:
  - leaked part of the recovery e-mail: m****n@me.com
- Amazon:
  - Name + Billing Address == full account compromise
  - Leaked last 4 digits of VISA after
- Apple:
  - Public information + 4 Digits of VISA == full account compromise

Something you **have**

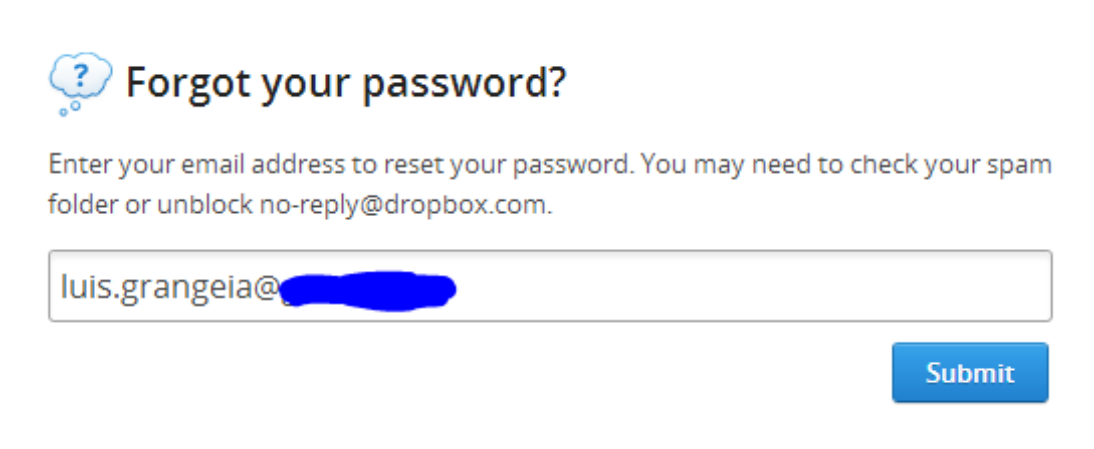
- Smartcards
- One Time Password tokens / Authenticators

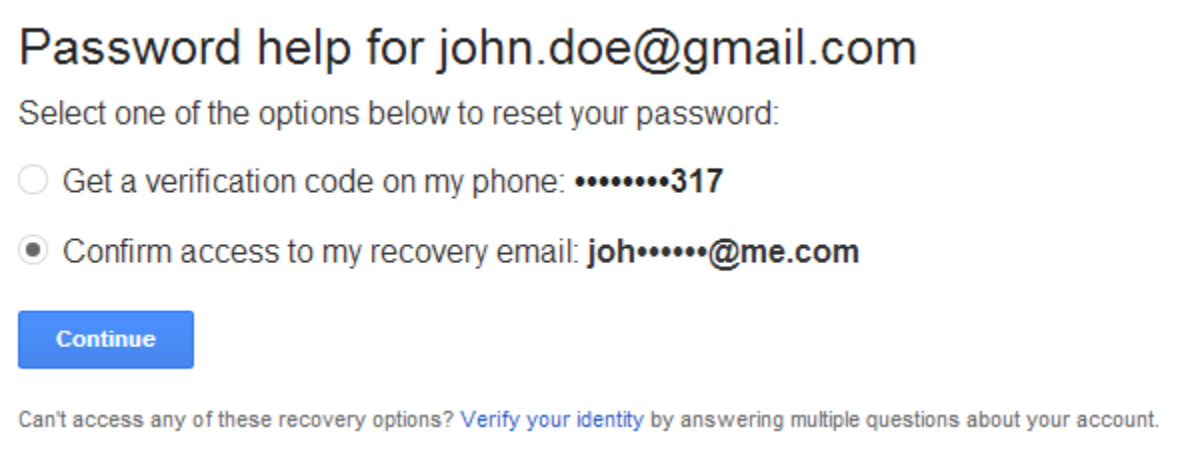
Something you **have**

- Access to a previously authenticated/trusted device
  - Access to a mobile phone number (SMS/voice code)
  - Access to a mobile app (authenticator)

Something you **have**

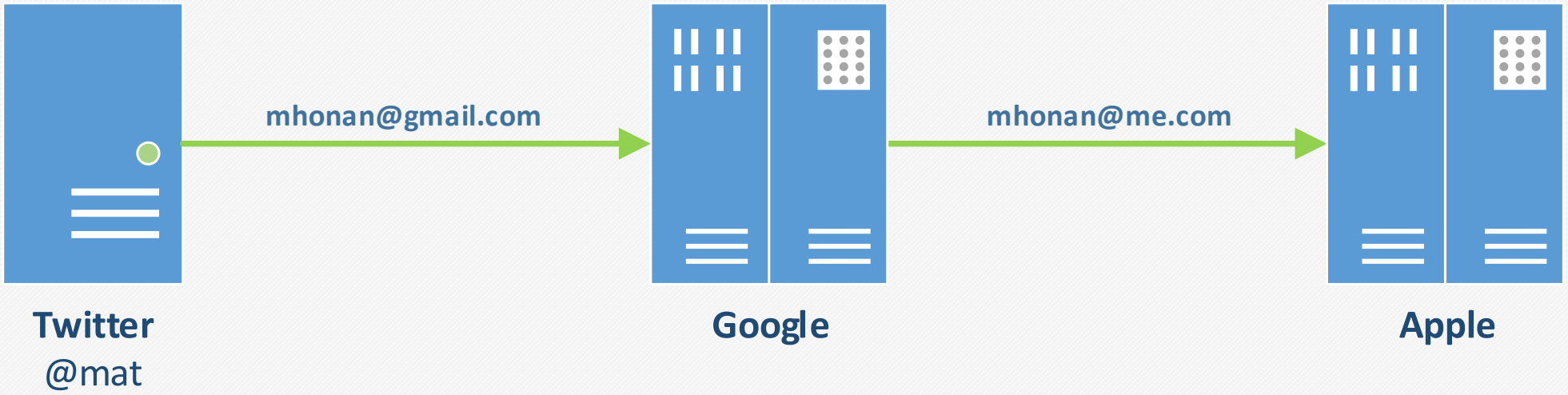
- Access to third party accounts (email)
  - Frequently used for password resets





Something you **have**

- **In the Mat Honan hack:**
- No second factor authentication used
- Chained trust relationships:

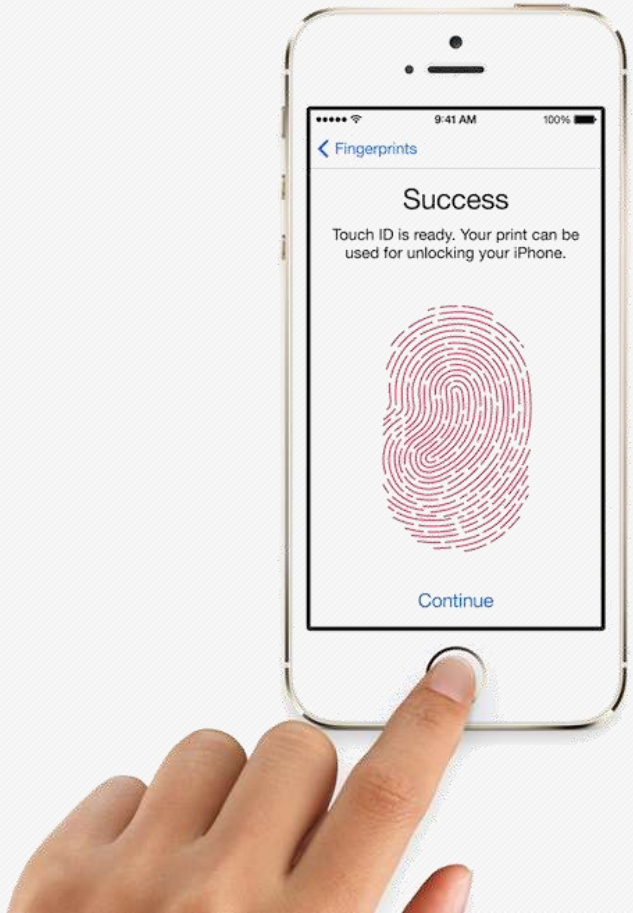


Something you **are**

- Biometrics

- Still a gimmick but is now seeing a boost in usage:
  - Android Face Unlock
  - iPhone 5S Touch ID
  - Voice recognition (in Google Now, probably Siri later)
  - Xbox One (the creepiest of them all)

Something you **are**



Something you **are**

- **Problems:**
- Biometrics is only good for local device authentication
  - Not fit for network authentication
  - Unless you want to see your biometric info travelling through the Internet…
- Must trust device completely
  - Specially if its connected to a network!
  - What happens if the device steals our biometric info or uploads it to the cloud?
- If you lose the device, you lose your bio data to the attacker.

Something you **are**

- **In the Mat Honan hack:**

- Biometrics was not used at all
- Would not have prevented anything, as biometrics is only useful for local (physically proximate) device authentication.

Authentication: Is this it?

- Something you **know**
- Something you **have**
- Something you **are**
- **???**

Is this all there is?

How do we humans authenticate ourselves?

Context Information

- **Context!**

- Complements Authentication
  - Helps quantify trust

- Where you are (location)
- What are you doing (behavior)
- Who are you talking to (social relations)

Context: location

Google Apps Alert: Suspicious login detected

Inbox x

Google Apps <apps-noreply@google.com> 18:00 (3 minutes ago)

to me

Hi,

This is to inform you that Google has detected a suspicious login for [redacted] in your domain refractiv.co.uk, on Friday, 13 September 2013 17:56:35 British Summer Time. The details are:

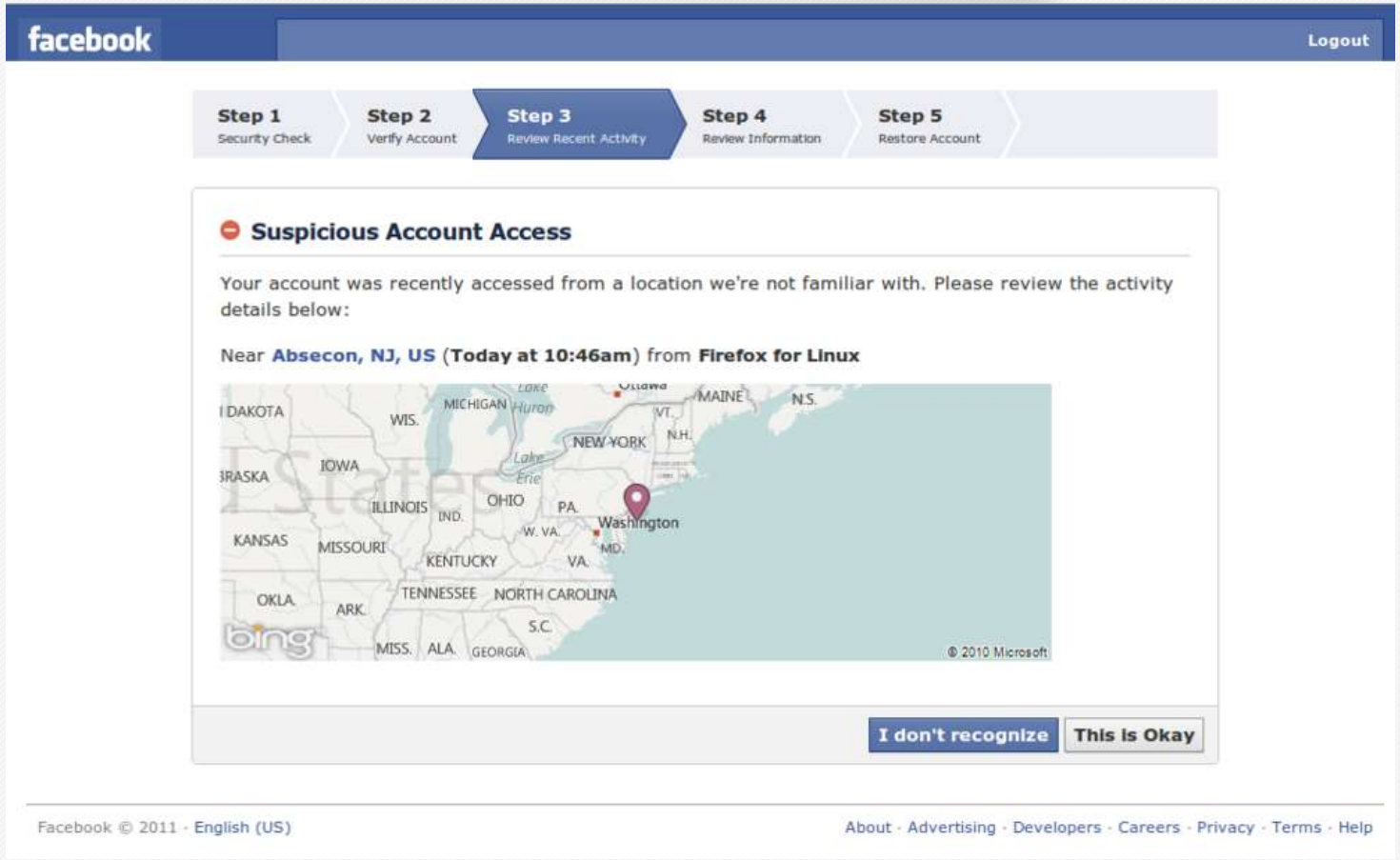
User: [redacted]
IP from which the login attempt was detected: 216.4[redacted]
Location: Los Angeles, CA, USA
Time: Friday, 13 September 2013 17:56:35 British Summer Time
Service: Gmail
Domain from where the login was detected (rDNS):

ACTIONS REQUIRED

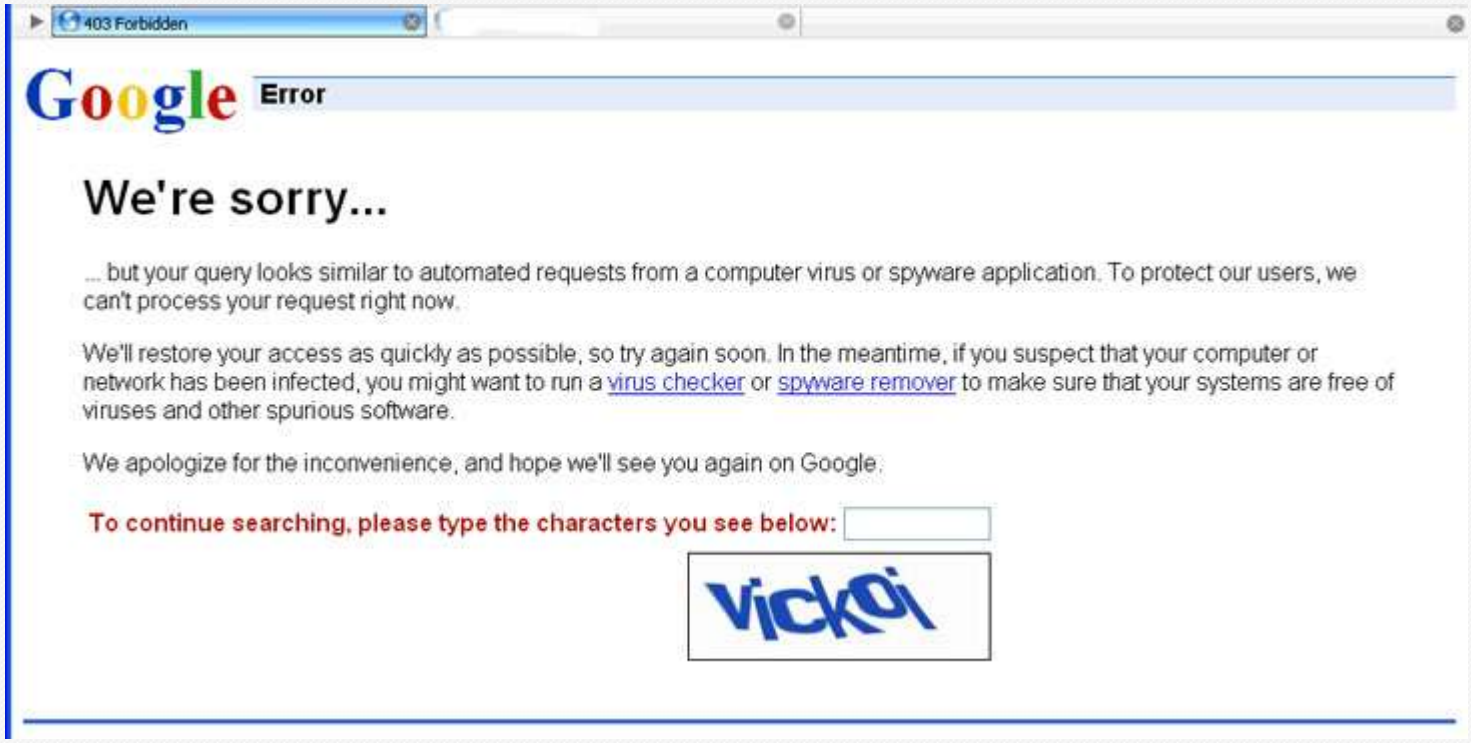
Please follow these instructions:

http://support.google.com/a/bin/answer.py?hl=en&hlrm=en&answer=2984349

Regards,
Google Apps team



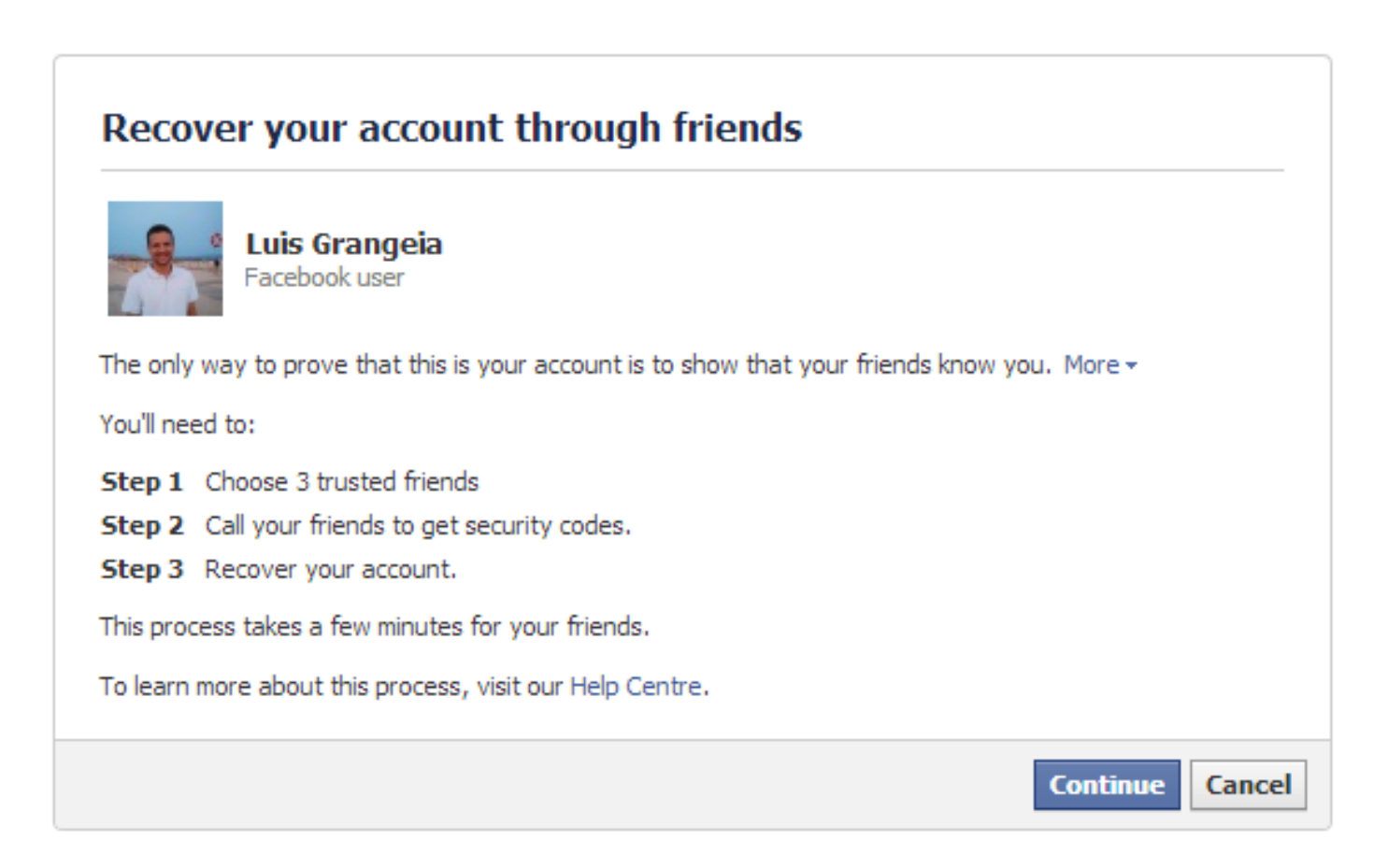
Context: behavior



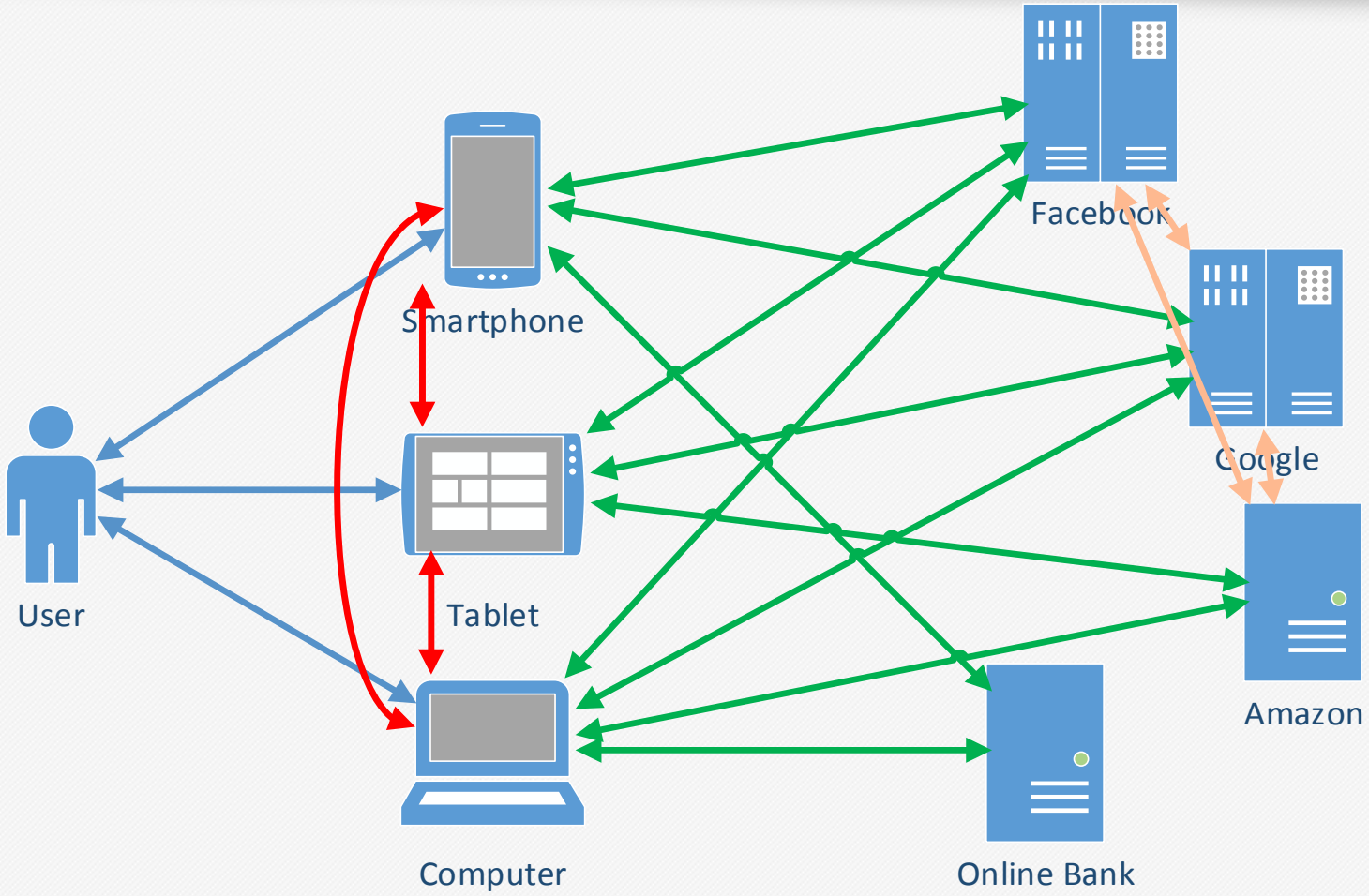
ACTIMIZE
a NICE company

"Actimize has core offerings across all financial crime prevention and compliance areas built on a unified reporting and case management platform. Actimize is known for its use of analytics and modeling techniques that ***uncover anomalous financial transactions, like fraud, money laundering and market manipulation****."*

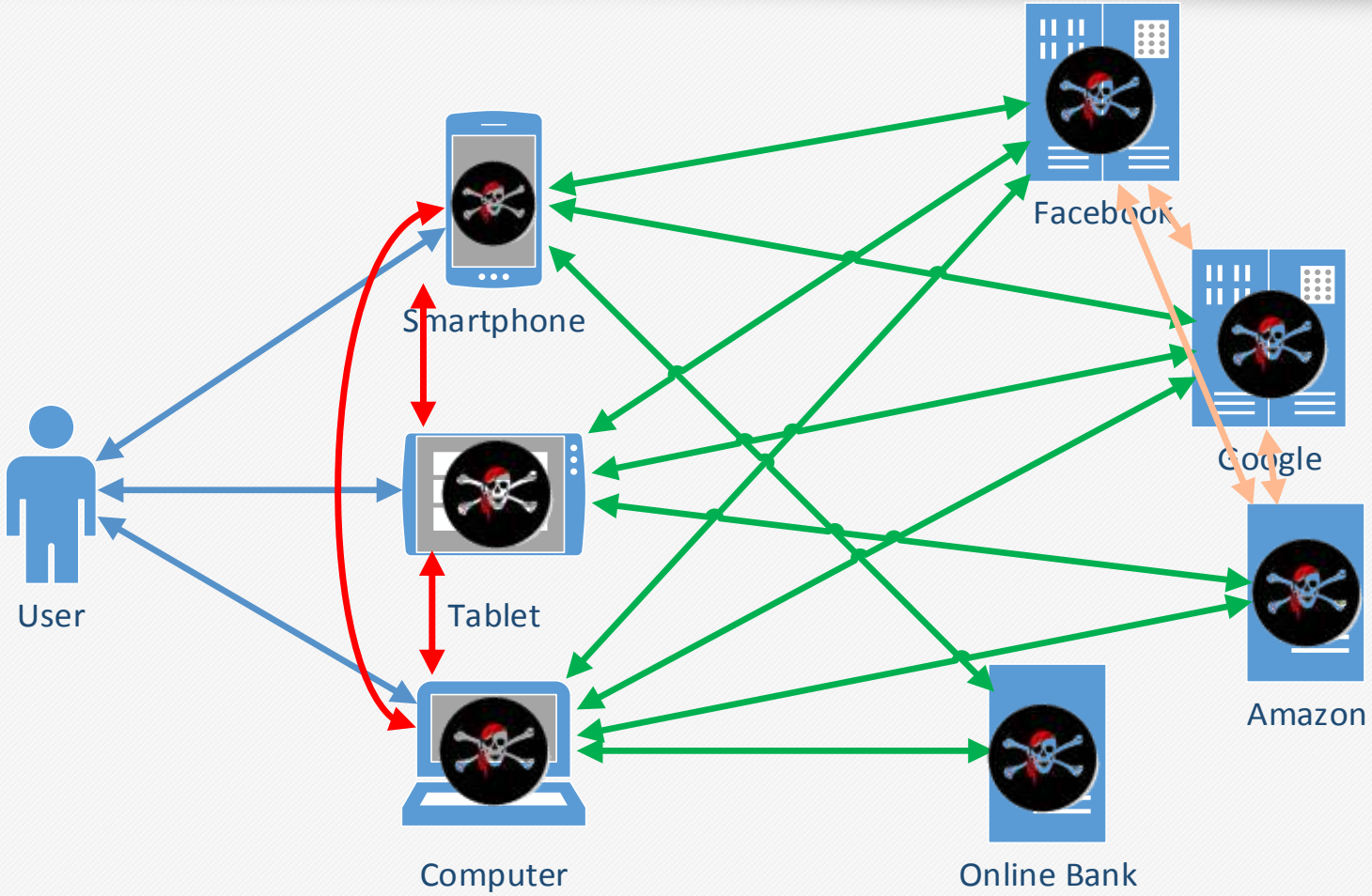
Context: social relations



Users, Devices, Services
Trust relationships everywhere



Users, Devices, Services
Trust relationships everywhere



Future Tendencies

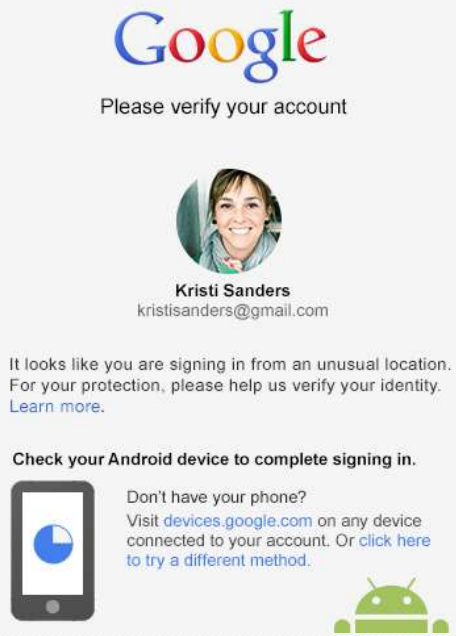
How will authentication & trust mechanisms evolve

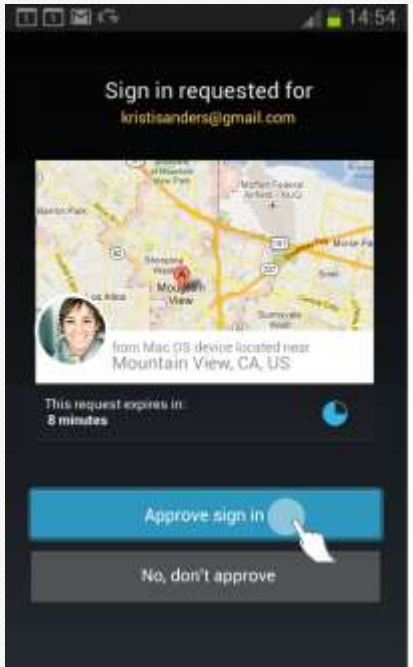
Future Tendencies: Device Authentication

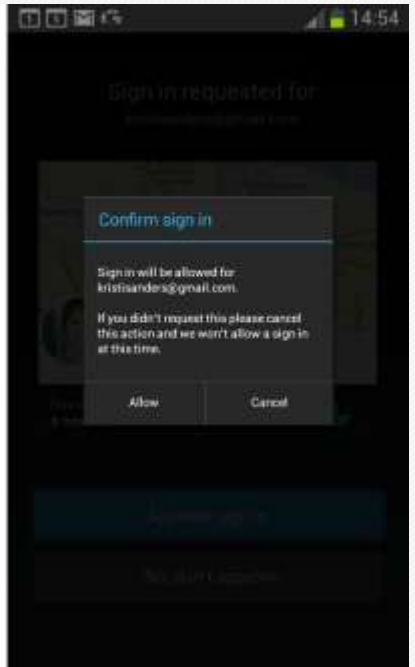
- Inexpensive wearable devices creating a “personal network” that reinforces trust (and increases the number of authentication factors):
  - Bionym’s Nymi
    - (adds biometrics)
  - NFC rings/wristband
  - Smartwatches

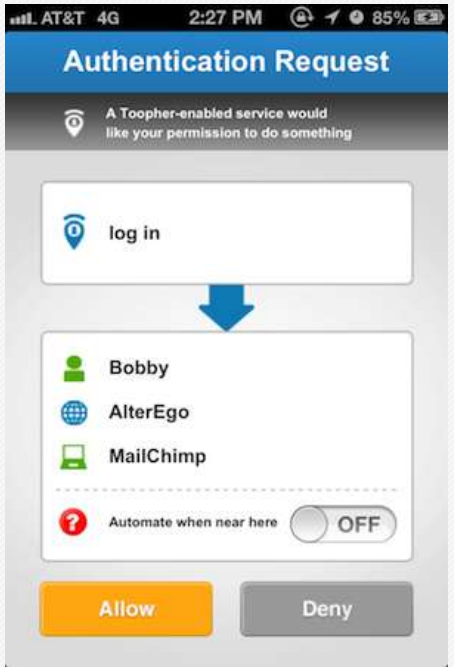
Future Tendencies: Service Authentication

- Increased usage of contextual factors for authentication:
  - Toopher
  - Next generation Google Authenticator



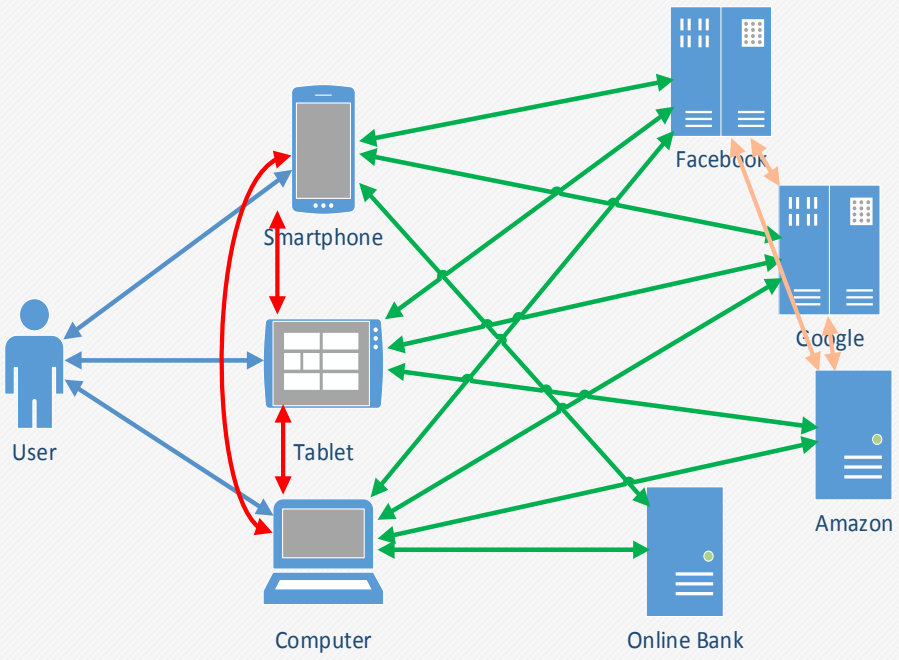






Future Tendencies: Service Authentication

- More trust relationships == more trust
- That's why multiple device (multiple factor) authentication is important
- The more the service knows about you, the more he can use to verify your identity:
  - Facebook
  - Google
  - Apple



Strategies

Takeaways for better identity management

(safety not guaranteed)

Something you **know**: Passwords

- **Password Strategies**
- Use different passwords for every service
- Long and randomly generated
- Stored in a password vault:
  - Keepass
  - 1Password
  - Password Safe
- Cloud synced **encrypted** password storage is a good compromise
- Several key files on your cloud storage
  - Plausible deniability
  - Segregation of virtual “personas”
- Avoid trusting your passwords to one single online service
  - Lastpass

Something you **know**: Other

- **Security Questions & Personal Information**

- **Strategies:**
- Never provide meaningful answers to security questions
  - Give out a different random answer and treat it like a password
- Beware of services with lax/faulty procedures for account recovery
  - Apple, Amazon (presumably better by now)

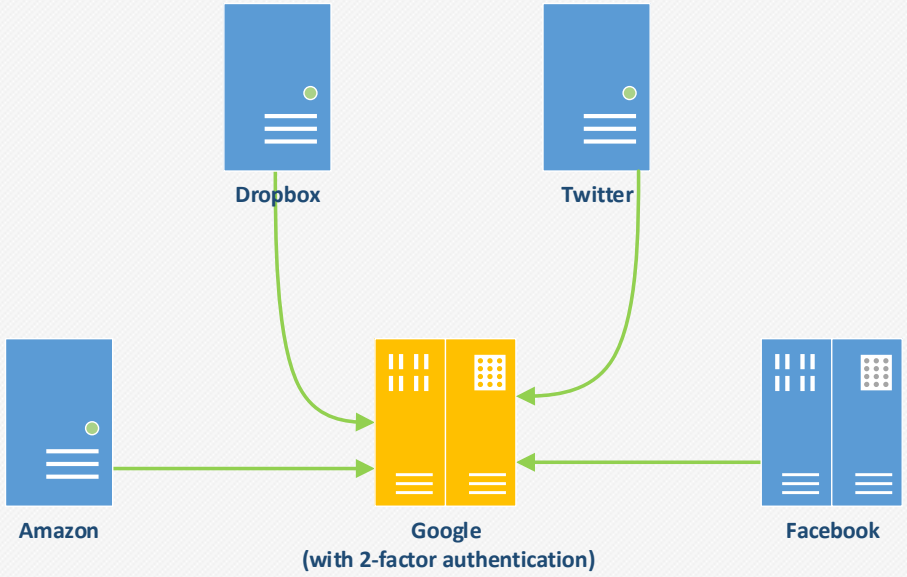
Something you **have**

- **Strategies:**

- Put all the eggs on one basket and protect the basket!
  - Make all accounts password reset go to a secure 2-factor account (eg. Google)

Audit your accounts / services

- Regularly audit the relations between your services
  - Password reset tokens (avoid the Mat Honan mistake)
  - Look at what information leaks on password reset procedures for some services



Something you **are**

- **Strategies:**

- Use biometrics sparingly and only on devices you really trust
- Beware of companies uploading your bio data to the cloud (Microsoft)
- Have a plan ready if the device gets lost / stolen
  - More on this later
  - Hope that remote wipe works well ☺

Increasing Trust in Devices

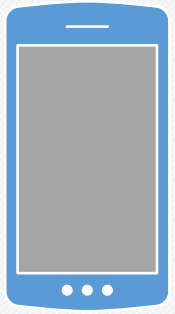
- Have a plan if your phone/laptop gets stolen:
  - Did you have encryption in place?
  - Did you have pin/pattern/password lock?
  - What information was in it?
  - What information/accounts might be compromised?
  - Can you remotely wipe the device? How fast can you do it?
  - Can you de-authorize the device on the registered services?

Increasing Trust in Devices

- All your access to Internet services via devices!
- Make it so losing only one device does not grant the new owner long term access to important services

Location History / Other Context Information

+



Smartphone

+

Bluetooth ECG Wristband

= OK

Closing Thoughts

- No one is more interested than securing your online identities than you. No one will do it for you!
- Having access to several services and devices should be a strength, not a weakness.
- Plan for the loss/theft of a device or the compromise of a service. It will happen.
- Look for vulnerabilities in Password Reset/Change Security Information Procedures on Microsoft/Google/Facebook.
  - You'll be amazed ☺

Thank you!

luis.grangeia@gmail.com